Synoptis: 信頼性の高い MCP エージェントネットワークのための相互アテステーション

Masaomi Hatakeyama

Genomics on Blockchain

DOI: 10.5281/zenodo.19161453

日付: 2026 年 3 月

概要

Model Context Protocol（MCP）は、AI エージェントが外部サーバの提供するツールを動的に発見・実行することを可能にし、柔軟なマルチエージェントネットワークを構築する。しかし、この動的な能力獲得は根本的な信頼問題を引き起こす。エージェントが実行時に利用可能な能力を変更できる場合、静的な許可リストや単一プロトコルのアテステーションでは信頼性のある相互作用を保証するには不十分である。AttestMCP に関する最近の研究では、MCP 内に能力アテステーションを追加することで攻撃成功率が 52.8% から 12.4% に低減されることが示されているが、この手法は一方向的かつ中央集権的な検証に依存している。本論文では、MCP エージェントが互いの振る舞いについて双方向に暗号署名された主張を行い、ハッシュチェーンによる改ざん検知ログに対して検証可能な相互アテステーションプロトコル **Synoptis** を提案する。Synoptis は 3 つの貢献を提供する：(1) 異議申し立てとローカルな信頼更新のためのチャレンジ・レスポンス機構を備えた双方向アテステーションプロトコル、(2) 品質・鮮度・多様性・速度・取消状態の 5 次元動的信頼スコアモデル、(3) 合意プロトコルを必要としないローカルなブロックチェーン級の完全性保証を提供する追記専用ハッシュチェーンレジストリである。Synoptis を KairosChain [22]（自己参照型 MCP サーバフレームワーク）のモジュラー SkillSet として実装する。MCP セキュリティ、分散型アイデンティティ、ブロックチェーンベースの信頼、マルチエージェント評判にわたる関連研究のサーベイを通じて、我々の知る限り、MCP エージェントネットワークにおける相互暗号アテステーションと改ざん検知ログを組み合わせた既存システムは存在しないことを特定する。プロトコル仕様を提示し、4 つの攻撃シナリオ（ツールポイズニング、Sybil 攻撃、共謀、スコア操作）に対するセキュリティ特性を分析し、ハッシュチェーンログとフルブロックチェーン合意の間の意図的な選択を含む設計上のトレードオフを議論する。

キーワード： Model Context Protocol、相互アテステーション、信頼スコア、マルチエージェントセキュリティ、改ざん検知ログ、MCP エージェント

---

1. はじめに

AI エージェントが Model Context Protocol（MCP）[1] を通じて動的に能力を獲得・合成・取消できるとき、他のエージェントはそれをどのように信頼すべきか。この問いは理論的なものにとどまらない。MCP エコシステムは 2024 年の Anthropic による導入以来急速に成長し、MCP サーバはファイルシステムアクセスからデータベースクエリ、コード実行に至るまでのツールを提供している。各ツール呼び出しは信頼境界を越え、能力獲得の動的な性質は、エージェントの信頼性を静的に評価できないことを意味する。

最近のセキュリティ分析はこの環境における具体的な攻撃ベクトルを文書化している。Maloyan と Namiot [2] は MCP における 3 つの重大な脆弱性を特定した：能力アテステーションの不在、オリジン認証なしの双方向サンプリング、ツールチェーン全体にわたる暗黙的信頼伝搬である。彼らが提案した AttestMCP 拡張はサーバ側の能力アテステーションを導入し、攻撃成功率を 52.8% から 12.4% に低減した。しかし、AttestMCP は単一の MCP セッション内で動作し、中央集権的な検証機関に依存しており、クロスエージェント間の信頼は未対応のままである。

動機となる例：エージェントマーケットプレイスにおけるスキルの信頼性。 MCP エージェントが共有のミーティングプレイス——ゲノミクスパイプライン、データ可視化、コード分析などのツールを提供する分散型スキル

マーケットプレイス——を通じて能力を発見・交換するネットワークを考える。他のエージェントのツールを呼び出す前に、エージェントはそのツールが信頼できるかどうかを評価する必要がある。現在の中央集権的アプローチ——GitHub のスターでランク付けする MCP サーバレジストリ、プラットフォームが審査する OpenAI GPT Store、ダウンロード数に依存する npm のようなパッケージマネージャ——は共通の限界を持つ：信頼は静的で中央集権的なシグナルによって使用前に確立され、デプロイ後には適応しない。初回審査を通過したツールが後に変更、侵害、劣化しても、マーケットプレイスの評価は変わらない。さらに、これらのシステムは提供者のみを評価し、消費者の振る舞いは監視されない。Synoptis は使用後、相互的、かつ時間的に動的な信頼評価を可能にすることでこれに対処する：エージェントは実際の相互作用の後に互いの振る舞いについてアテストし、信頼スコアは積極的に維持されなければ減衰し、スキル提供者と消費者の双方が評価の対象となる。この統合を HestiaChain——エージェントが中央集権的ランキングなしにスキルを交換し、Synoptis アテステーションを信頼の基盤として使用するミーティングプレイス実装——を通じて実証する（第 4.1 節参照）。

本論文では、このギャップに対応する MCP エージェントネットワーク向けの相互アテステーションプロトコル **Synoptis** を提案する。我々の貢献は以下の通りである：

- **C1: MCP エージェント向け双方向相互アテステーションプロトコル。** 2 つの MCP エージェントが互いの振る舞いについて暗号署名された主張を行い、異議申し立てとローカルな信頼更新のためのチャレンジ・レスポンス機構を備える。AttestMCP の一方向モデルとは異なり、Synoptis はエージェント間の対称的な信頼評価を可能にする。双方向アテステーション自体は他の文脈（PGP の web-of-trust、相互 TLS など）に存在するが、Synoptis は我々の知る限り、改ざん検知永続化を伴う MCP エージェントエコシステムに適用した最初のプロトコルである。
- **C2: 5 次元動的信頼スコア。** 二値的な信頼判定ではなく、Synoptis は品質・鮮度・多様性・速度・取消の 5 次元にわたる連続的な信頼スコアを計算し、微細で時間変化する信頼評価を可能にする。
- **C3: ハッシュチェーン改ざん検知レジストリ。** すべてのアテステーション、取消、チャレンジ・レスポンス記録が SHA-256 ハッシュチェーンを持つ追記専用ログに保存され、合意プロトコルなしで検証可能なローカルな完全性保証を提供する。

本論文の構成は以下の通りである。第 2 節で背景と脅威モデルを定義する。第 3 節で関連研究をサーベイする。第 4 節で Synoptis プロトコルを提示する。第 5 節でセキュリティ特性を分析する。第 6 節で限界と将来の研究を議論する。第 7 節で結論を述べる。

---

2. 背景と脅威モデル

2.1 MCP と動的能力獲得

Model Context Protocol [1] は AI エージェントホストとツール提供サーバ間の JSON-RPC 2.0 ベースのインタフェースを定義する。MCP サーバはツールのセットを公開し、各ツールは名前、説明、入力スキーマによって記述される。エージェントは `tools/list` メソッドで利用可能なツールを発見し、`tools/call` で実行する。重要なことに、利用可能なツールのセットは実行時に変更可能である：サーバはツールの追加・削除・変更を行うことができ、エージェントはセッション中に新しいサーバに接続できる。

動的能力獲得を、ツールの発見・合成・委任を通じて実行中にエージェントの実効的な能力セットが変化するプロセスと定義する。これは静的設定とは異なり、Synoptis が対処する信頼の課題を導入する：時刻 t に信頼できたエージェントが、侵害されたサーバによって能力を獲得または変更され、時刻 $t+1$ には信頼できなくなっている可能性がある。

2.2 脅威モデル

N 個の MCP エージェントのネットワークを考える。各エージェントは MCP サーバを運用し、他のエージェントのサーバに接続する可能性がある。MCP ネットワーク向けに適応した Dolev-Yao 攻撃者モデル [3] の変種を採用する：

攻撃者の能力： - 攻撃者は f 個のエージェントを制御する。ここで $f < N/3$ をセキュリティ分析のための共謀サイジングパラメータとして使用する。この閾値は BFT 文献から信頼スコアモデル（第 5.3 節）における共謀耐性分析の便宜的な上界として採用したものであり、Synoptis が BFT スタイルの合意保証を提供することを意味しない。Synoptis は合意プロトコルを実行しないためである。- 侵害されたエージェントは任意のアテステーションを発行し、主張を偽造し、チャレンジ応答を選択的に保留できる。- 攻撃者はすべてのネットワークトラフィックを観察できるが、誠実なエージェントの RSA-2048 署名を偽造することはできない。- 攻撃者は誠実なエージェントのローカル改ざん検知ログを変更できない。

攻撃シナリオ：

- **ツールポイズニング**。侵害された MCP サーバが肯定的なアテステーションを受け取った後にツールの振る舞いを変更し、アテステーション時と実行時のギャップを悪用する。
- **Sybil 攻撃**。攻撃者が複数のアイデンティティを作成して信頼スコアの多様性次元を水増しし、悪意あるエージェントの信頼性について偽のコンセンサスを製造する。
- **共謀**。複数の侵害されたエージェントが相互に肯定的なアテステーションを発行し、人為的に高い信頼スコアを確立する。
- **スコア操作**。攻撃者がアテステーションのタイミングを戦略的に調整して速度次元を悪用し、攻撃開始前にスコアを膨張させるバーストを生成する。

前提条件： - 各誠実なエージェントは RSA-2048 鍵ペアを所持する。鍵配布には Trust-On-First-Use（TOFU）を使用する。TOFU は初回鍵交換時の中間者攻撃に対して脆弱であることに注意する。高セキュリティ環境では、より強力なブートストラップ機構（組織的 PKI、鍵式典など）が必要となる場合がある（第 6.2 節参照）。- 誠実なエージェントのローカルファイルシステムは完全性保護されている（すなわち、攻撃者は誠実なエージェントのストレージ上の追記専用ログを改ざんできない）。- ネットワーク通信は信頼性に欠ける場合があるが、攻撃者によって無期限に選択的に遅延されることはない。

明示的な非目標： - 侵害後セキュリティは提供しない。署名鍵の侵害は攻撃者が将来のアテステーションを偽造することを可能にし、その鍵で署名されたすべての過去のアテステーションを信頼できないものにする。- アテステーション層に対するサービス拒否攻撃には対処しない。- Sybil 耐性は外部のアイデンティティメカニズム（鍵式典、組織的信頼など）に依存する。Synoptis はアイデンティティブートストラップ問題を解決しない。- リプレイ攻撃は `proof_id` の一意性チェック（第 4.2 節）によって部分的に緩和されるが、包括的なリプレイ保護機構（シーケンス番号や nonce ベースのプロトコルなど）は将来の課題とする。- アテステーション証拠のプライバシーには対処しない。すべてのアテステーション記録はレジストリにアクセスできるすべてのエージェントに可視である。

---

3. 関連研究

4 つの領域にわたる関連研究をサーベイする。本サーベイは MCP セキュリティ、分散型アイデンティティ、ブロックチェーンベースの信頼、マルチエージェント評判に関する 2022 年から 2026 年の文献をレビューし、以下に 21 の代表的論文を引用する。

3.1 MCP セキュリティ

MCP 仕様 [1] はトランスポート層セキュリティ（TLS）と OAuth 2.1 認証を定義するが、クロスエージェント能力アテステーションの機構は提供しない。Maloyan と Namiot [2] は最も直接的に関連する先行研究を提示する：AttestMCP は信頼された機関によって検証されるサーバ側の能力宣言を導入する。彼らの評価はプロンプトインジェクション攻撃成功率の 52.8% から 12.4% への低減を示す。しかし、AttestMCP は中央集権的な信頼機関を持つ単一セッション内での一方向検証（サーバがクライアントに対してアテスト）に限定される。Synoptis はこの研究を双方向、分散型、永続的アテステーションに拡張する。

Hou ら [4] は MCP セキュリティ脅威の包括的サーベイを提供し、能力アテステーションのギャップ、サンプリングの脆弱性、信頼伝搬リスクを特定する。彼らの脅威分類法は第 2.2 節の脅威モデルに反映されている。

Anbiaee ら [16] は MCP、A2A、Agora、ANP プロトコルにわたる比較セキュリティ脅威モデルを提示する。Ehtesham ら [5] によるより広範なサーベイは MCP を A2A、ACP、ANP プロトコルと比較し、現在のすべてのエージェント相互運用プロトコルがクロスエージェント検証のための組み込み信頼メカニズムを欠いていることを指摘する。

3.2 検証可能クレデンシャルと分散型アイデンティティ

W3C 検証可能クレデンシャル（VC）および分散型識別子（DID）標準 [6] はクレームの発行、提示、検証のためのフレームワークを提供する。Garzon ら [7] は DID/VC を AI エージェントのアイデンティティに適用し、エコシステム間でのクレデンシャルポータビリティを実現する。しかし、W3C VC はパブリックインフラストラクチャ向けに設計されており、検証可能データレジストリ（通常はパブリックブロックチェーン）の利用を前提とする。Synoptis はエージェントがパブリックチェーンインフラにアクセスできない可能性のある許可型環境で動作し、アテステーションは外部台帳ではなくローカルに完全性保証付きで記録される。

3.3 ブロックチェーンベースの信頼と監査

いくつかのシステムはエージェント調整と信頼のためにブロックチェーンインフラを使用する。Jackson [8] はゼロ知識検証と Shapley 値ベースの完全性チェックを持つ DAO-Agent を提案する。Observer Protocol [9] は Bitcoin メインネット上で AI エージェント間のリアルタイム暗号証明決済を実証した。しかし、これらのアプローチはパブリックチェーントランザクションのレイテンシとコストを伴い、MCP ツール呼び出しに必要な高頻度・低レイテンシのアテステーションには実用的でない。Hu ら [17] は自己主権型分散 AI エージェントに内在するガバナンスの緊張関係を分析し、自律性と説明責任のバランスをとるアテステーション機構の動機を提供する。

AuditTrust [10] などのブロックチェーンベースの監査証跡システムはデータ共有のための改ざん検知ログを提供するが、エージェント間アテステーションではなく人間対システムの相互作用を対象とする。Synoptis のハッシュチェーンレジストリは合意プロトコルを必要とせず同等の完全性保証を提供し、各参加者がローカルにログを維持する許可型エージェントネットワークに適している。

3.4 マルチエージェント信頼と評判

マルチエージェントシステムの信頼・評判モデルは広く研究されている [11]。最近の研究は AI エージェント固有の課題に対処する：TRiSM フレームワーク [12] はエージェンティック AI の信頼・リスク・セキュリティ管理の次元を特定するが、具体的なプロトコルを提供しない。Mansa AI 評判レイヤー [13] は Web3 エージェントの構造化メトリクスを導入するが、形式的なエージェント間アテステーションを欠く。Ren ら [14] は生成的マルチエージェントシステムにおける評判操作リスク（共謀エージェントや隠しトリガーを含む）を特定する——これはまさに Synoptis が検出するよう設計された攻撃シナリオである。Schroeder de Witt [20] はマルチエージェントセキュリティにおける未解決課題のより広範なサーベイを提供し、Rajagopalan と Rao [18] および Doshi ら [19] はそれぞれ認証済みワークフローと LLM エージェントの検証可能な安全なツール使用に取り組んでいる——Synoptis のアテステーション焦点と補完的な関心事である。

ギャップの要約。我々の知る限り、以下を組み合わせた既存システムは存在しない：(1) AI エージェント間の双方向相互アテステーション、(2) 時間とともに進化する動的信頼スコア、(3) 合意オーバーヘッドなしの改ざん検知永続化、(4) MCP プロトコルエコシステムとの統合。Synoptis はこのギャップに対応する。

---

4. Synoptis プロトコル

4.1 設計原則

Synoptis は 3 つの原則に基づいて設計されている：

合意なしのブロックチェーン級ローカル完全性。ブロックチェーンシステムの完全性保証——追記専用ストレージ、ハッシュチェーン、暗号検証——を、合意プロトコルを必要とせずに目標とする。我々の実装はハッシュチ

ェーン改ざん検知ログを使用する：各レコードは先行レコードの SHA-256 ハッシュを含み、検証可能なチェーンを形成する。これはローカルな完全性（誠実なエージェントが自身のログが改ざんされていないことを検証できる）を提供するが、グローバルな合意（エージェントが単一の正規の履歴に合意する）は提供しない。許可型 MCP ネットワークにおいて、エージェントが自身のログを維持しアテステーションプロトコル自体を通じて相互検証する場合、このトレードオフは適切と考える。

観察ベースの信頼。信頼は宣言された意図ではなく、観察可能な証拠（アテステーション、チャレンジ、レスポンス）から計算される。これは分散ネットワークにおいて振る舞いが唯一の信頼できるシグナルであるという原則と整合する（DEE モデル [15]、ポストコンセンサス型協調に関する我々の関連研究を参照）。

トランスポート独立性。アテステーションプロトコルは通信層から独立して定義される。Synoptis は 3 つのトランスポートをサポートする：サーバ間通信のための MMP（Model Meeting Protocol、KairosChain ドキュメント参照）、ローカルネットワーク通信のための Hestia（LAN 発見プロトコル、KairosChain ドキュメント参照）、同一マシン上のエージェント間のローカル配信である。アテステーションロジックを変更せずに新しいトランスポートを追加できる。

MCP 統合モデル。 Synoptis は MCP 上のアプリケーション層オーバーレイとして実装され、KairosChain MCP サーバフレームワーク内の SkillSet（プラグイン）としてデプロイされる。アテステーション操作は標準 MCP ツール（`attestation_issue`、`attestation_verify`、`attestation_revoke`、`attestation_list`、`challenge_create`、`challenge_respond`、`trust_query`）として公開され、標準の `tools/call` メソッドで呼び出し可能である。エージェントは他のエージェントの MCP サーバからツールを呼び出す前に、`trust_query` ツールを使用して蓄積されたアテステーション証拠に基づく信頼スコアを評価する。

構造的注記：統一的構成要素としての SkillSet。 KairosChain では、トランスポート層（MMP）、発見層（HestiaChain Meeting Place）、アテステーション層（Synoptis）がすべて SkillSet——同じプラグインアーキテクチャ、同じ API 表面、同じ進化メカニズム——として実装されている。この統一性は実用的な帰結を持つ：Synoptis は自身を含むあらゆる SkillSet の振る舞いについてアテストできる。エージェントは他のエージェントの Synoptis 実装が正しく動作しているか（チャレンジへの応答、ハッシュチェーンの完全性維持など）についてアテステーションを発行できる。この自己参照的特性——信頼検証層自体が同じ信頼スコアメカニズムを通じて信頼検証の対象となる——は、エージェントの Synoptis 実装が他のエージェントからのアテステーションによって計算される独自の信頼スコアを持つことを意味する。誤動作する、あるいは悪意のあるアテステーションエンジンは、それ自身が実装するプロトコルによって検出可能である。これは追加機能ではなく、すべてのプロトコル層を SkillSet として実装したことの構造的帰結である。この特性の適応的スコアリングへの含意を第 6.3 節で探る。

4.2 ProofEnvelope

Synoptis の基本データ単位は **ProofEnvelope**（構造化アテステーションレコード）である：

```
ProofEnvelope := {
  proof_id:       UUID v4,
  version:        "1.0.0",
  attester_id:    String,     // MCPインスタンス識別子
  subject_ref:    String,     // アテステーション対象（以下の例を参照）
  claim:          String,     // アテステーション主張
  evidence:       String?,    // 裏付け証拠（オプション）
  merkle_root:    String?,    // 選択的開示用（オプション）
  signature:      String?,    // RSA-SHA256, Base64エンコード
  timestamp:      ISO 8601,   // UTC
  ttl:            Integer,    // 有効期間（秒）
  actor_user_id:  String?,    // 監査証跡: トリガーしたユーザー（実装固有）
  actor_role:     String?,    // 監査証跡: トリガーしたユーザーの役割（実装固有）
  metadata:       Object?     // 任意の拡張性（実装固有）
}
```

subject_ref フィールドはアテステーション対象を識別する。例：- "agent:mcp-server-alpha" —エージェントの全体的な振る舞いについてアテスト - "tool:code_execute@agent-B" —特定のエージェント上の特定のツールについてアテスト - "invocation:uuid:abc-123" —特定のツール呼び出し結果についてアテスト

正規形。決定論的ハッシュを保証するため、JSON 正規化スキーム（JCS, RFC 8785 [21]）の簡略化サブセットに従う正規 JSON 表現を定義する。正規形はコアフィールド（proof_id、version、attester_id、subject_ref、claim、evidence、merkle_root、timestamp、ttl）を含み、実装固有フィールド（signature、actor_user_id、actor_role、metadata）を除外する。フィールドは辞書順にソートされ、nil 値は省略せず JSON null として明示的に保持される。**コンテンツハッシュ**はこの正規形に対する SHA-256 として計算される。

署名。暗号素材が利用可能な場合、ProofEnvelope は RSA-2048 と SHA-256 を用いて署名される：

```
signature = Base64(RSA-Sign(SHA256, canonical_json(envelope)))
```

検証にはアテスターの公開鍵が必要であり、TOFU または事前共有鍵配布を通じて取得される。

リプレイ緩和。受信者は以前に観察された proof_id 値を持つ ProofEnvelope を拒否すべき（SHOULD）である。ttl フィールドと組み合わせることで、限定的なリプレイ保護が提供される：リプレイされたエンベロープは既知の proof_id を持つか、有効期限が切れているかのいずれかである。

4.3 通常のアテステーションフロー

チャレンジ・レスポンス機構を説明する前に、標準的な双方向アテステーションライフサイクルを概説する：

```
エージェントA                          エージェントB
   |                                    |
   |---- tools/call (Bのツール使用) ----->|
   |<--- ツール結果 ----------------------|
   |                                    |
   |  [AがBのツール動作を評価]            |
   |                                    |
   |---- attestation_issue -------------->|
   |  (subject_ref: "tool:X@agent-B",     |
   |   claim: "correct_output",           |
   |   evidence: "hash_of_result",        |
   |   signature: RSA-Sign(A))            |
   |                                    |
   |  [Bが独立にAを評価]                  |
   |                                    |
   |<--- attestation_issue ---------------|
   |  (subject_ref: "agent:agent-A",      |
   |   claim: "legitimate_invocation",    |
   |   signature: RSA-Sign(B))            |
   |                                    |
   |  [両エージェントが受信した            |
   |   アテステーションをローカルの        |
   |   ハッシュチェーンレジストリに保存]   |
```

図 1. 通常の双方向アテステーションフロー。各エージェントは独立に相手を評価し、署名付きアテステーションを発行する。肯定的なアテストは必須ではなく、否定的な主張（例: "anomalous_behavior"）も同じフローに従う。

4.4 信頼スコアモデル

Synoptis は各対象について、その対象を参照する n 個のアテステーションのセットから連続的な信頼スコア S □ [0, 1] を計算する。スコアは 5 次元の重み付き線形結合である：

$$S = \text{clamp}\left(\sum_{d \in D} w_d \cdot s_d - w_r \cdot p_r,\ 0,\ 1\right)$$

ここで D = {品質, 鮮度, 多様性, 速度}、*w_d* は次元重み、*s_d* □ [0, 1] は次元スコア、*w_r* は取消ペナルティ重み、*p_r* □ [0, 1] は取消比率、n は対象のアテステーション総数である。

表 1. 信頼スコアの次元とデフォルト重み。

次元	重み	定義	根拠
品質	0.30	証拠、Merkle ルート、署名を持つ証明の割合	裏付け証拠と暗号的結合を持つ高品質なアテステーションはより信頼できる
鮮度	0.25	30 日窓内の平均近時性：$\bar{f} = \frac{1}{n}\sum_i \max(1 - \frac{a_i}{720}, 0)$（$a_i$ は経過時間）	最近のアテステーションはより関連性が高い。古いアテステーションは 720 時間（30 日）にわたり線形に減衰
多様性	0.25	アテステーション数に対するユニークアテスター比率（キャップ付き）：$\min\left(\frac{\lvert\text{ユニークアテスター数}\rvert}{\min(n,10)}, 1\right)$	多様なソースからのアテステーションは偽造が困難。Sybil 増幅を制限するため 10 でキャップ
速度	0.10	アテステーション率：$\min\left(\frac{n/\Delta t}{5}, 1\right)$（$\Delta t$ は日数単位の期間）	持続的なアテステーション活動は継続的な関与を示す。1 日 5 アテステーションに正規化
取消	0.10	ペナルティ：$\frac{\lvert\text{取消数}\rvert}{n}$	取消されたアテステーションは信頼を比例的に低下させる

重みの正当化。デフォルト重みは設計上の優先度を反映する：証拠の品質とソースの多様性がスコアの 55% を占め、信頼は主に独立したソースからの検証可能な証拠に基づくべきという原則を反映する。具体的な値（0.30, 0.25, 0.25, 0.10, 0.10）は設定可能なデフォルト値である。これらの重みがゲーム理論的分析から導出されたものではないことを明示的に注記する。形式的な均衡分析は将来の重要な課題である（第 6.3 節）。720 時間の鮮度窓と 1 日 5 アテステーションの速度正規化はアクティブなエージェントネットワーク向けの合理的なデフォルトとして選択されている。異なる活動パターン（週次バッチ処理など）のデプロイメントでは、これらのパラメータを適宜調整すべきである。

線形性の正当化。単純性と解釈可能性のために線形結合を選択する。各次元は独立かつ比例的に総合スコアに寄与する。非線形モデル（乗法的、閾値ベースなど）は次元間の相互作用を捉え得るが、線形モデルは透明な分解の利点を持つ：実務者が各次元の寄与を検査してスコアが高いまたは低い理由を理解できる。

4.5 チャレンジ・レスポンスプロトコル

エージェントがアテステーションに異議を唱える際、Synoptis は異議申し立てとローカルな信頼更新のための構造化されたチャレンジ・レスポンスプロトコルを提供する。Synoptis はグローバルに拘束力のある解決メカニズムを課さず、各エージェントが自身の信頼ポリシーに従ってチャレンジの結果を解釈することを強調する。

状態： - `pending`：チャレンジ発行済み、応答待ち。- `responded`：元のアテスターが署名付き応答を提供した。- `expired`：応答タイムアウト超過（デフォルト：3600 秒）。

プロトコルフロー：

1. **チャレンジ作成**。エージェント A がアテステーション P に対してチャレンジタイプ □ {`validity`, `evidence_request`, `re_verification`} を指定してチャレンジを行う。システムは（a）アテステーション P の存在、（b）P の対象に対するアクティブチャレンジ数が `max_active_per_subject` = 5 を超えないこと、（c）チャレンジが未発行であることを検証する。`max_active_per_subject` 制限はチャレンジフラッディングを特に緩和するものであり、明示的な非目標（第 2.2 節）である一般的なサービス拒否耐性を構成するものではないことに注意する。

2. **チャレンジ配信**。チャレンジは利用可能なトランスポート（MMP、Hestia、またはローカル）を通じて元のアテスターに配信される。

3. **応答**。元のアテスターのみが応答可能。応答は元のアテスターの秘密鍵によって暗号署名されなければならず（MUST）、応答のなりすましを防止する。応答にはオプションの証拠が含まれ、追記専用ログに記録される。

4. **ローカル評価**。チャレンジを行ったエージェントが応答内容を評価し、それに応じて信頼を調整するかどうかを決定する。グローバルな仲裁者は存在しない。解決はローカルである。

3600 秒のタイムアウトは、応答しないアテスターがチャレンジ解決を無期限にブロックしないことを保証する。応答なしで期限切れとなったチャレンジは、それ自体が信頼性の欠如の証拠となる。

```
    チャレンジャー              アテスター
       |                        |
       |--- challenge_create ->|
       |   (type, proof_id)     |
       |                        |
       |<-- challenge_respond--|
       |   (evidence, response,|
       |    signature)          |
       |                        |
  [ローカル評価]                |
```

図 2. チャレンジ・レスポンスプロトコルフロー。

4.6 レジストリとトランスポート

ハッシュチェーンレジストリ。すべてのレコード（アテステーション、取消、チャレンジ）は追記専用 JSONL 形式で保存される。各レコードは先行レコードの SHA-256 ハッシュを含む `_prev_entry_hash` フィールドを含む：

```
record[i]._prev_entry_hash = SHA256(canonical_json(record[i-1]))
```

各チェーンの最初のレコードは `_prev_entry_hash = null` である。チェーンの完全性はハッシュを順次再計算することで検証可能——チェーンの途切れは改ざんを示す。並行書き込みはファイルレベルの排他ロックを用いてシリアライズされる。各エージェントが自身のローカルログを維持し、エージェント間でログのグローバルな一貫性を保証する機構は存在しないことに注意する。原理的に、エージェントは異なるピアに対して異なるアテステーション履歴を提示することが可能である（二重性、equivocation）。チャレンジ・レスポンスプロトコルを通じた相互検証は部分的な緩和を提供するが、完全な二重性検出には分散ログ比較が必要であり、これは将来の課題とする。

取消レコード。取消はタイプ `revocation` の別個のレジストリエントリとして記録され、元の `proof_id` を参照する。取消は元のアテスターまたは権限を持つ管理者によって署名されなければならない。取消されたアテステーションはログ内に残り（ハッシュチェーンを維持）、信頼スコア計算においては肯定的証拠としては除外

される。ただし、取消ペナルティ次元（第 4.4 節、表 1）には引き続き寄与する。取消されたアテステーションはクエリ結果においてそのようにフラグされる。

トランスポート抽象化。 Synoptis は 4 つの操作を持つトランスポートインタフェースを定義する：`send_attestation`、`send_revocation`、`send_challenge`、`send_challenge_response`。3 つの実装が提供される：

- **MMP トランスポート**：Model Meeting Protocol（KairosChain MMP SkillSet で定義）を用いた HTTP 上のサーバ間通信。メッセージには送信者のインスタンス ID と認証用のベアラトークンが含まれる。
- **Hestia トランスポート**：Hestia LAN 発見プロトコル（KairosChain Hestia SkillSet で定義）を用いたローカルネットワーク通信。
- **ローカルトランスポート**：同一マシン上のエージェント間（マルチテナントデプロイメントなど）でアテステーションを配信。

トランスポート選択は設定可能なフォールバック順序（デフォルト：MMP → Hestia → ローカル）に従い、実行時に可用性が検出される。

---

5. セキュリティ分析

第 2.2 節で定義された 4 つの攻撃シナリオに対する Synoptis のセキュリティ特性を分析する。この分析はプロトコル設計に基づく定性的なものであり、シミュレートされたエージェントネットワークによる実証的評価は将来の課題として計画されている。

5.1 ツールポイズニング検出

ツールポイズニング攻撃では、エージェント M が肯定的なアテステーションを受け取った後にツールの振る舞いを変更する。Synoptis は時間的証拠を通じてこれを検出する：

1. エージェント A が M の変更されたツールを呼び出した後に異常な動作を観察する。
2. A は証拠（振る舞いの差分、予期しない出力など）を含む否定的アテステーションを発行する。
3. A はチャレンジ・レスポンスプロトコルを通じて M の既存の肯定的アテステーションにチャレンジする。
4. M がタイムアウト（3600 秒）内に応答しない場合、チャレンジは期限切れとなり、未回答のチャレンジ自体が信頼性の欠如の証拠となる。
5. M の信頼スコアは 3 つのメカニズムにより低下する：(a) 否定的アテステーションが品質を低下させる、(b) 肯定的アテステーションが経年化し鮮度が低下する、(c) 既存アテステーションの取消が取消ペナルティを増加させる。

重要な設計特性は、**信頼スコアは静的ではない**ということである：明示的な否定的証拠がなくても、鮮度の減衰（720 時間の線形減衰窓）により、継続的な肯定的アテステーションによって積極的に維持されない限り、信頼は自然に低下する。

5.2 Sybil 耐性

多様性次元はユニークアテスターを $\min(n, 10)$ でキャップする。これは限定的な Sybil 耐性を提供する：k 個のアイデンティティを制御する攻撃者は多様性スコアに最大 $k/10$（$n \geq 10$ の場合）しか寄与できず、収穫逓減となる。しかし、Synoptis は根本的な Sybil 耐性を提供しない——任意のアイデンティティを生成できる攻撃者は多様性キャップを飽和させることができる。

多次元スコアリングによる緩和。 攻撃者が Sybil アイデンティティを通じて多様性を水増ししても、品質次元は証拠と署名を要求し（大規模な偽造にはコストがかかる）、速度次元は 1 日 5 アテステーションに正規化される（バースト攻撃を制限）。次元の組み合わせは多層防御を提供する：1 つの次元を侵害するだけでは高い信頼スコアを達成するには不十分である。

5.3 共謀耐性

f 個の侵害されたエージェントが互いのスコアを水増しするために共謀する場合、Synoptis の多様性次元は部分的な検出を提供する。アテステーション総数 n が十分に大きく多様性キャップが作用する場合（すなわち $\min(n, 10) = 10$）の共謀下での最大達成可能信頼スコアを分析する。

この仮定の下で、ある対象に対するすべての肯定的アテステーションが同じ f 個の共謀エージェントグループから発生する場合、多様性スコアは $f/10$ で上界される。$N = 10$ で $f < N/3$（すなわち $f \leq 3$）の場合、最大達成可能信頼スコアは：

$$S_{\max} = 0.30 \times 1.0 + 0.25 \times 1.0 + 0.25 \times \frac{f}{10} + 0.10 \times 1.0 - 0.10 \times 0$$

$f = 3$ の場合：$S_{\max} = 0.30 + 0.25 + 0.25 \times 0.3 + 0.10 = 0.725$。これは合理的な信頼閾値 0.8 を下回り、$n \geq 10$ のデフォルトパラメータ下では共謀する少数派が「高信頼」ステータスを達成できないことを意味する。

小 n に関する注意。アテステーション数が少ない場合（例：$n = 3$ でいずれも異なる共謀エージェントからの場合）、多様性スコアは 1.0 に達し得る（$\min(n, 10) = n = 3$ であり、$3/3 = 1.0$）。この領域では共謀の上界は成立せず、共謀エージェントは任意に高い信頼スコアを達成できる。このコールドスタート脆弱性は限られた証拠を持つすべての評判システムに内在するものであり、重要な判断に信頼スコアを使用する前に十分なアテステーション量を確立することの重要性を強調する。

5.4 スコア操作耐性

速度次元は 1 日 5 アテステーションに正規化され、アテステーション頻度の総合スコアへの寄与を上限づける。1 時間に 100 アテステーションを発行する攻撃者は、20 日間にわたり 1 日 5 つを発行するものと同じ速度スコア（1.0）を達成する——速度次元は持続的な活動とバースト的な活動を区別しないことを、現行の線形モデルの限界として認識する。多様性キャップと組み合わせると、複数のアイデンティティを制御しない限り、速度操作は限定的な利益しかもたらさない。

5.5 AttestMCP との比較

表 2. セキュリティ特性の定性的比較。AttestMCP は対照実験からの測定された攻撃低減を報告し、Synoptis の特性はプロトコル設計に対する分析的推論から導出されていることに注意する。

特性	AttestMCP [2]	Synoptis
方向性	一方向	双方向
検証モデル	中央集権的機関	分散型（ピアツーピア）
永続性	セッション限定	ハッシュチェーン改ざん検知ログ
攻撃面低減	52.8% → 12.4%（実測）	5 次元による多層防御（分析的）
紛争機構	なし	チャレンジ・レスポンス（ローカル解決）
共謀耐性	未対応	$n \geq 10$ のとき $f < N/3$ で有界
信頼の粒度	二値（アテスト済み/未）	連続 [0, 1]
時間的動態	静的	減衰ベース（720h 鮮度窓）

AttestMCP と Synoptis は MCP セキュリティの補完的な側面に対処する。AttestMCP は単一の MCP セッション内でサーバ能力を検証し、Synoptis はセッションとエージェントを越えて縦断的な信頼を構築する。2 つのアプローチは組み合わせ可能である：MCP サーバはセッション層の能力検証に AttestMCP を、クロスエージェント評判に Synoptis を使用できる。

6. 議論、限界、将来の課題

6.1 ハッシュチェーンログ対ブロックチェーン

Synoptis のレジストリを「ブロックチェーン」ではなく「ハッシュチェーン改ざん検知ログ」と意図的に記述した。ハッシュチェーン機構はブロックチェーンシステムに類似した完全性保証を提供するが、我々の実装は合意プロトコルを欠く：各エージェントが自身のログを維持し、すべてのエージェントが単一の正規の履歴に合意するメカニズムは存在しない。これは二重性（equivocation）が可能であることを意味する：エージェントは異なるピアに対して異なるアテステーション履歴を提示できる。これはグローバルな整合性を要求するシナリオ(紛争の拘束力ある仲裁など）における根本的な制限である。しかし、各エージェントがローカルに観察された証拠に基づいて独立に信頼を評価する相互アテステーションのユースケースにおいては、ローカルな完全性で十分である。軽量な合意プロトコルまたは分散ログ比較による二重性検出で Synoptis を拡張することは将来の自然な方向性である。

6.2 限界

侵害後セキュリティ。 Synoptis はエフェメラル鍵交換なしで RSA-2048 署名を使用する。エージェントの秘密鍵の侵害は攻撃者が将来のアテステーションを偽造することを可能にし、その鍵で署名されたすべての過去のアテステーションを信頼できないものにする。トランスポート暗号化のためのエフェメラル Diffie-Hellman 鍵交換の統合は将来の課題とする。RSA-2048 が現在のデフォルトであることに注意する。アルゴリズムの俊敏性（Ed25519 やポスト量子方式のサポートなど）は本仕様では扱わない実装上の考慮事項である。

TOFU 脆弱性。 Trust-On-First-Use 鍵配布モデルは初回鍵交換時の中間者攻撃に対して脆弱である。2 つのエージェント間の最初の接触を傍受する攻撃者は自身の公開鍵を代替でき、以降のすべての署名検証を無効化する。強力な初期信頼を要求するデプロイメントでは、組織的 PKI または帯域外鍵検証を使用すべきである。

Sybil 耐性。多様性次元はユニークアテスターを 10 でキャップし、限定的な Sybil 緩和を提供する。しかし、Synoptis は根本的な Sybil 問題を解決しない：任意のアイデンティティを生成できる攻撃者は多様性スコアを水増しできる。オープンネットワークにおける Sybil 耐性には外部のアイデンティティメカニズム（組織的 PKI、鍵式典など）が必要である。

スケール。線形スキャンクエリを用いる JSONL ベースのレジストリは大規模ネットワークにスケールしない。インデックス付きクエリを持つ SQLite またはデータベースバックエンドのレジストリは計画されているが未実装である。

信頼スコアの重み。デフォルト重みは経験的に動機づけられているが形式的に導出されたものではない。信頼スコアメカニズム下での均衡戦略のゲーム理論的分析——特に合理的な攻撃者が線形スコアモデルをゲームできるかどうか——は重要な未解決問題である。

実証的検証。本論文はプロトコル設計と分析的セキュリティ評価を提示する。信頼スコア重みの感度分析、ビザンチンエージェント検出率、性能ベンチマークを含む実証的評価は即座のフォローアップ研究として計画されている。

6.3 将来の課題

現在の設計からいくつかの将来の研究方向が浮上する。最も直近の優先事項は、シミュレートされたマルチエージェントネットワークによる実証的評価であり、重み設定にわたる信頼スコア感度分析、様々な攻撃者比率下でのビザンチンエージェント検出率、アテステーション作成・検証・スコア計算のレイテンシ/スループットベンチマークを含む。TLA+ や ProVerif などのモデル検査ツールによるチャレンジ・レスポンスプロトコルの形式検証は、プロトコルの正当性特性への信頼を強化する。合理的攻撃者下での信頼スコア均衡のゲーム理論的分析は、線形スコアモデルが悪用可能な戦略を許容するかどうかを判断するために必要である。インフラストラクチャ面では、クロスエージェントログ検証のための分散 Merkle ツリーが完全なログレプリケーションなしでの二重性検出を可能にし、観察された攻撃パターンに基づく適応的重み調整がデプロイメントに新たな脅威への対応を可能にする。

より根本的に、いかなる固定スコアリングモデルも、そのパラメータを学習した合理的攻撃者によって最終的にはゲーム可能である。KairosChain の自己参照的 SkillSet アーキテクチャはこの課題に対する構造的な回答を提供する：Synoptis が SkillSet として実装されているため、スコアリングモデル自体を他のシステムコンポーネントと同じメカニズムで進化させることができる。重みの調整、モデルの置換、さらには進化ルール自体の変更も、改ざん検知ログに記録される SkillSet 操作として表現可能である。これは静的なゲーム（攻撃者対固定ルール）を共進化的動態（攻撃者対進化するルール）に変換し、システムの不完全性——すべての攻撃を予見できないこと——が継続的な適応の駆動力となる（DEE モデルのゆらぎを通じた秩序の原則 [15] を参照）。

---

7. 結論

MCP エージェントネットワークのための相互アテステーションプロトコル Synoptis を提示した。MCP セキュリティ、分散型アイデンティティ、ブロックチェーンベースの信頼、マルチエージェント評判にわたる関連研究のサーベイを通じて、ギャップを特定した：我々の知る限り、MCP エージェントにおける双方向暗号アテステーション、動的信頼スコア、改ざん検知永続化を組み合わせた既存システムは存在しない。Synoptis はこのギャップに 3 つの貢献で対応する：チャレンジ・レスポンス異議申し立てを備えた双方向アテステーションプロトコル、5 次元動的信頼スコアモデル、合意オーバーヘッドなしのローカルなブロックチェーン級完全性を提供する追記専用ハッシュチェーンレジストリである。

我々のセキュリティ分析は、プロトコルが有界な共謀耐性（十分なアテステーション証拠が存在する場合、$N = 10$ 中 $f \leq 3$ の共謀少数派はデフォルトパラメータ下で信頼スコア 0.725 を超えることができない）、Sybil およびスコア操作攻撃に対する多次元スコアリングによる多層防御、鮮度減衰によるツールポイズニング検出のための時間的信頼低下を提供することを示唆する。侵害後セキュリティの欠如、限定的な Sybil 耐性、TOFU 脆弱性、グローバル合意の欠如における二重性の可能性、実証的検証の必要性を含むプロトコルの限界を明示的に文書化した。

Synoptis は KairosChain MCP サーバフレームワーク [22] 内のオープンソース SkillSet として実装されている。実証的評価と形式検証は即座のフォローアップ研究として計画されている。

参考文献

[1] Anthropic, “Model Context Protocol Specification,”2024. https://modelcontextprotocol.io/specification

[2] N. Maloyan and D. Namiot, “Breaking the Protocol: Security Analysis of the Model Context Protocol Specification and Prompt Injection Vulnerabilities in Tool-Integrated LLM Agents,”arXiv:2601.17549, 2026.

[3] D. Dolev and A. Yao, “On the security of public key protocols,”IEEE Transactions on Information Theory, vol. 29, no. 2, pp. 198–208, 1983.

[4] X. Hou, Y. Zhao, S. Wang, and H. Wang, “Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions,”arXiv:2503.23278, 2025.

[5] A. Ehtesham et al., “A Survey of Agent Interoperability Protocols: Model Context Protocol (MCP), Agent Communication Protocol (ACP), Agent-to-Agent Protocol (A2A), and Agent Network Protocol (ANP),”arXiv:2505.02279, 2025.

[6] W3C, “Verifiable Credentials Data Model v2.0,”W3C Recommendation, 2025. https://www.w3.org/TR/vc-data-model-2.0/

[7] S. R. Garzon, A. Vaziry, E. M. Kuzu, D. E. Gehrmann, B. Varkan, A. Gaballa, and A. Küpper, “AI Agents with Decentralized Identifiers and Verifiable Credentials,”arXiv:2511.02841, 2025.

[8] F. Jackson, “Agentic Blockchain Intelligence: Designing Secure Decentralized AI Agents with Smart Contract Governance,”SSRN:5869322, 2025.

[9] Observer Protocol, “Two AI agents, different stacks, settled a payment on Bitcoin mainnet,”2026. https://observerprotocol.org

[10] F. A. Solórzano et al., “A Blockchain-Based Audit Trail Mechanism: Design and Implementation,” Algorithms, vol. 14, no. 12, p. 341, 2021. DOI: 10.3390/a14120341.

[11] G. Granatyr, S. S. Botelho, O. R. Lessing, E. E. Scalabrin, J.-P. Barthès, and F. Enembreck, “Trust and Reputation Models for Multiagent Systems,”ACM Computing Surveys, vol. 48, no. 2, 2015. DOI: 10.1145/2816826.

[12] S. Raza, R. Sapkota, M. Karkee, and C. Emmanouilidis, “TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems,”arXiv:2506.04133, 2025.

[13] Mansa AI, “Agent Reputation Layer Framework,”2025.

[14] S. Ren, W. Fu, X. Zou, C. Shen, Y. Cai, C. Chu, Z. Wang, and S. Hu, “Reputation as a Solution to Cooperation Collapse in LLM-based Multi-Agent Systems,”arXiv:2505.05029, 2025.

[15] M. Hatakeyama, “DEE: Decentralized Evolving Ecosystem —A Post-Consensus Model for AI Agent Communities,”Zenodo, 2026. DOI: 10.5281/zenodo.18583107（関連研究）.

[16] Z. Anbiaee et al., “Security Threat Modeling for Emerging AI-Agent Protocols: A Comparative Analysis of MCP, A2A, Agora, and ANP,”arXiv:2602.11327, 2026.

[17] B. A. Hu et al., “Trustless Autonomy: Understanding Motivations, Benefits, and Governance Dilemmas in Self-Sovereign Decentralized AI Agents,”arXiv:2505.09757, 2025.

[18] M. Rajagopalan and V. Rao, “Authenticated Workflows: A Systems Approach to Protecting Agentic AI,”arXiv:2602.10465, 2026.

[19] A. Doshi et al., “Towards Verifiably Safe Tool Use for LLM Agents,”arXiv:2601.08012, 2026.

[20] C. Schroeder de Witt, “Open Challenges in Multi-Agent Security: Towards Secure Systems of Interacting AI Agents,”arXiv:2505.02077, 2025.

[21] A. Rundgren, B. Jordan, and S. Erdtman, “JSON Canonicalization Scheme (JCS),”RFC 8785, Internet Engineering Task Force, June 2020. https://www.rfc-editor.org/rfc/rfc8785

[22] M. Hatakeyama, “KairosChain: A Self-Referential MCP Server Framework,”2026. DOI: 10.5281/zenodo.19161453. https://github.com/masaomi/KairosChain_2026